# Security Hardening Plan for a 100-User Business

## Executive summary

This 12-week security hardening plan prioritizes five integrated controls designed to address the most significant attack paths facing a 100-user organization: credential compromise, privileged account misuse, endpoint infection, phishing, and data exposure. The roadmap strengthens identity security, governs external access, reduces the endpoint attack surface, automates threat detection and response, and improves data protection and recovery. Each control is introduced through pilot, audit, report-only, or simulation modes before enforcement, allowing a two-person administration team to improve security while minimizing user disruption and operational risk. The required capabilities are expected to be available within the organization's Microsoft 365 E7 licensing, subject to confirmation of the tenant's assigned service plans and feature entitlements.

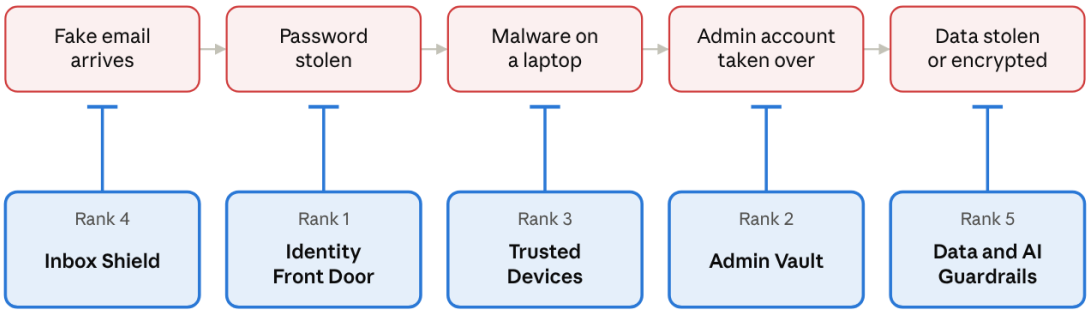
**The top five, ranked by how much risk each one removes:**

1. **Identity Front Door** (Conditional Access + passwordless sign-in) - every sign-in is checked for who, where, which device and how risky, before any access is given.
2. **Admin Vault** (Privileged Identity Management + break-glass accounts) - admin power is borrowed for a few hours, never held all the time.
3. **Trusted Devices** (Intune + Defender for Endpoint) - only healthy, managed devices reach company data, and ransomware is stopped on the device.
4. **Inbox Shield** (Defender for Office 365 + DMARC) - phishing, malware and fake-invoice emails are blocked before users see them.
5. **Data and AI Guardrails** (Purview + Copilot and agent governance) - sensitive files stay inside, whether the leak would come from a person, a device or Copilot.

The plan is built for two admins who also have other jobs. It leans on Microsoft's ready-made templates, "report-only" and "audit" modes, small pilot groups, and automation. Each control is tested quietly first, then switched on for everyone.

**Each control breaks one step of a typical attack**

Top: how a typical attack unfolds. Bottom: the control that stops each step, with its rank.



attack chain · 5 steps, 5 controls

An attacker has to win every step. Each control breaks a different step, so even if one fails, the next one still stands.

## Environment and assumptions

The business has 100 users, two admins and Microsoft 365 E7 for everyone. E7 bundles Microsoft 365 E5, Microsoft 365 Copilot, Agent 365 and the Entra Suite in one license, so no extra security product needs to be bought for this plan.

**What E7 already includes for security:**

- **Identity:** Entra ID P2 (Conditional Access, Identity Protection, Privileged Identity Management) and the Entra Suite (ID Governance, Internet Access, Private Access).
- **Threat protection:** Defender XDR - Defender for Endpoint P2, Defender for Office 365 P2, Defender for Identity and Defender for Cloud Apps, all in one incident queue.
- **Devices:** Microsoft Intune for device and app management.
- **Data:** Microsoft Purview - sensitivity labels, data loss prevention (DLP), Insider Risk Management, eDiscovery and audit.
- **AI:** Microsoft 365 Copilot for every user, plus Agent 365 to track and govern AI agents.

**Assumptions this plan is built on:**

- Most staff use Windows laptops and mobile phones. Some phones are personal (BYOD).
- The two admins also run day-to-day IT. Neither works full-time on security, and there is no 24/7 security team.
- The tenant has security defaults or a few basic policies today, but no full Conditional Access design.
- Copilot is licensed but not yet in wide use, so data clean-up can happen before broad rollout.

> ***Threat picture for a business this size:*** *attackers rarely target a 100-user firm by name. They run mass campaigns - phishing, password spraying, fake invoices and ransomware - and take whoever is easiest. The goal is not to be perfect. It is to stop being the easy target.*

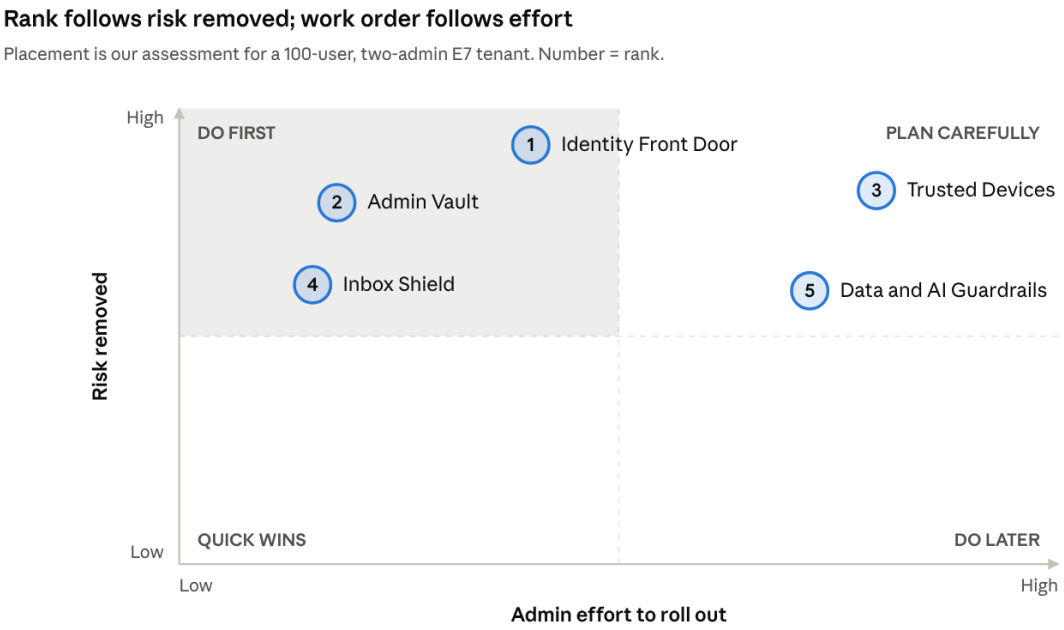
## How the controls were ranked

The rank answers one question: if only this control were missing, how much damage could get through? Effort decides the order of work, not the rank.

Each control was scored on four tests:

1. **How common is the attack it stops?** Sign-in attacks and phishing happen every day. Insider data theft is rarer.
2. **How bad is the damage?** Losing an admin account or getting hit by ransomware can stop the business. One leaked file usually does not.
3. **Does it unlock other controls?** Conditional Access is the engine that later enforces device health, admin rules and data rules. So it comes first.

4. **Can two admins run it?** Controls with good defaults, templates and automation score higher.




risk removed vs. admin effort · 5 controls

All five sit in the top half: none of them is optional. The three on the left start in weeks 1-3; the two heavy ones on the right get the longest runway in the roadmap.

## Control 1 · Identity Front Door

*Every sign-in is checked before anyone gets in.*

> ***Built with:*** *Entra Conditional Access, Identity Protection, passkeys in Microsoft Authenticator, Windows Hello for Business* · ***Effort:*** *Medium* · ***Owner:*** *Admin A*

### Why it matters

The user account is the real perimeter in Microsoft 365. Email, files, Teams and Copilot all sit behind one sign-in. If an attacker signs in as a user, every other control sees a "trusted" person.

Think of Conditional Access as a security guard at the front door. A password alone is just a name badge. The guard also checks the face (strong sign-in), the vehicle (device health), where they came from (location) and whether anything looks off (risk score) before opening the door.

### Risks it mitigates

- **Password spraying and stuffing** - attackers try common or leaked passwords across many accounts.
- **Push fatigue** - attackers spam approval prompts until a tired user taps "Approve".
- **Token theft through fake login pages** - a proxy page steals the session after the user signs in. Passkeys and Windows Hello stop this, because they only work on the real Microsoft site.

- **Legacy sign-in back doors** - old protocols (POP, IMAP, basic SMTP auth) skip modern checks entirely.
- **Risky sign-ins** - impossible travel, leaked credentials or anonymous IPs flagged by Identity Protection.

### Rollout with two admins

1. **Create two break-glass accounts first** (see Control 2), so a bad policy can never lock everyone out.
2. **Start from Microsoft's Conditional Access templates**, not from scratch. Core set:
    - Require strong authentication for all users
    - Block legacy authentication
    - Require passkey or Windows Hello sign-in for admin roles
    - Ask for re-authentication on medium or high sign-in risk; force a secure password change on high user risk
3. **Run every policy in report-only mode for 1-2 weeks.** Use the Conditional Access insights workbook to see who would have been blocked. Nothing breaks during this phase.
4. **Run a registration campaign.** Users register passkeys in Microsoft Authenticator from a short guide. Use a Temporary Access Pass for new joiners and lost phones, so the admins are not resetting accounts by hand.
5. **Switch on in waves:** IT and a 10-person pilot group first, then everyone a week later.
6. **Retire weak methods.** Turn off SMS and voice call in the authentication methods policy once most users have registered.
7. **Add device checks later.** After Control 3, the same policies start requiring a compliant device.

### Key configuration

A simple naming pattern (CA + number + target + action) keeps the policy list readable for both admins. Every policy excludes the two break-glass accounts.

- **CA01 - All users - Require strong sign-in.** All cloud apps. Grant: authentication strength *Multifactor authentication*.
- **CA02 - All users - Block legacy authentication.** Client apps: Exchange ActiveSync and other clients. Grant: block.
- **CA03 - Admins - Require passkey sign-in.** Target: all admin directory roles. Grant: the built-in *phishing-resistant* authentication strength (passkeys, Windows Hello, FIDO2 keys).
- **CA04 - All users - Risky sign-in.** Sign-in risk medium or high. Grant: strong sign-in. Session: sign-in frequency *every time*.
- **CA05 - All users - Risky user.** User risk high. Grant: strong sign-in + secure password change.
- **CA06 - All users - Block device code flow.** Authentication flows condition: device code flow. Grant: block. (A growing phishing trick that sends users to a real Microsoft page with an attacker's code.)
- **CA07 - All users - Protect security-info registration.** User action: register security information. Grant: strong sign-in or Temporary Access Pass, from trusted locations only.

**Supporting settings:**

- Authentication methods policy: passkeys (Authenticator) on, Temporary Access Pass on, SMS and voice off after the campaign.
- Number matching and app context stay on for any remaining push sign-ins.
- Self-service password reset on, with the same strong methods.
- Continuous access evaluation left at default (on), so a disabled account or risky event cuts sessions within minutes.

### Tradeoffs and drawbacks

- **User friction at the start.** Registration week brings questions. Plan short helpdesk hours and a one-page guide.
- **Old apps and devices break.** Scanners, printers and old mail tools using basic SMTP auth stop working. They need an inventory and a fix (modern auth or a dedicated relay) before enforcement.
- **Lockout risk.** A wrong policy can block the admins too. Break-glass accounts and report-only mode are the safety net.
- **Hardware cost (optional).** Staff without a suitable phone may need FIDO2 security keys.

## Control 2 · Admin Vault

*Admin power is checked out for a few hours, then handed back.*

> ***Built with:*** *Entra Privileged Identity Management (PIM), role-based access, Entra ID Governance access reviews, app consent controls* · ***Effort:*** *Low* · ***Owner:*** *Admin B*

### Why it matters

With only two admins, both usually hold Global Administrator every day, on the same account they use for email. That account opens phishing emails and browses the web. If it is taken over, the attacker gets the keys to everything: they can create hidden accounts, read every mailbox, turn off logging and delete backups.

Think of it like a bank vault. Staff don't carry the vault key in their pocket. They sign it out for a task, it is logged, and it goes back. Privileged Identity Management does exactly this for admin roles.

### Risks it mitigates

- **Tenant takeover** through one phished or malware-infected admin account.
- **Hidden persistence** - attackers adding their own admin accounts, app registrations or mail rules.
- **Malicious app consent** - users approving a fake app that gets long-term access to mail and files.
- **Mistakes with too much power** - a wrong click with Global Admin affects every user.
- **Lockout** - losing both admins' access through a bad policy, lost phone or staff leaving.

### Rollout with two admins

1. **Split each admin into two identities.** Daily account for email and Teams (no admin roles). Separate cloud-only admin account (e.g. adm-jane@tenant.onmicrosoft.com) with no mailbox and no Copilot license.

2. **Create two break-glass accounts.** Cloud-only, permanent Global Administrator, excluded from Conditional Access, protected by FIDO2 keys stored in two separate safes. Set an alert on any sign-in.
3. **Map daily tasks to small roles.** Most work needs only Exchange Administrator, Intune Administrator, Security Administrator or User Administrator - not Global Admin.
4. **Turn on PIM.** Make every admin role *eligible*, not permanent. Activation needs strong sign-in, a short reason, and lasts up to 4 hours.
5. **Lock down app consent.** Users can only consent to low-risk apps from verified publishers. Everything else goes through the admin consent workflow.
6. **Set up alerts and reviews.** Email alerts for role activation and new role assignments. A quarterly access review in Entra ID Governance confirms who still needs which role.
7. **Test break-glass every quarter.** Sign in, confirm it works, log it.

### Key configuration

- **Global Administrator:** eligible only; activation max 4 hours; strong sign-in on activation; justification required; notification to both admins.
- **Day-to-day roles** (Exchange, Intune, Security, User Admin): eligible; activation max 8 hours; no approval needed.
- **Permanent assignments:** only the two break-glass accounts.
- **Conditional Access:** CA03 (passkey sign-in for admins) applies to all admin roles; admin portals later also require a compliant device (Control 3).
- **User consent:** allow only for verified publishers and low-impact permissions; admin consent workflow sends requests to both admins.
- **Who can create:** restrict app registrations, new tenants and security groups to admins.
- **Audit:** alert rules for changes to Conditional Access policies, role assignments and federation settings.

### Tradeoffs and drawbacks

- **Slower urgent fixes.** Activating a role adds a minute or two before work starts. In an outage this can feel slow.
- **Approvals don't fit a two-person team.** If one admin is on leave, the other can't wait for approval. So this plan uses alerts instead of approvals for most roles.
- **More accounts to manage.** Separate admin and break-glass accounts mean more credentials to protect and test.
- **Break-glass is a risk in itself.** These accounts skip Conditional Access. They must be rare, monitored and physically protected.

## Control 3 · Trusted Devices

*Only healthy, managed devices get near company data.*

> ***Built with:*** *Microsoft Intune (enrollment, compliance, app protection), Defender for Endpoint P2, Windows Autopatch, attack surface reduction rules* · ***Effort:*** *High* · ***Owner:*** *Admin B*

### Why it matters

A strong sign-in does not help if the laptop itself is infected. Info-stealer malware copies browser sessions and passwords. Ransomware encrypts local and synced files. An unpatched laptop is an open window into the network.

Think of devices as cars entering a company car park. Intune is the inspection sticker: brakes checked, lights working, registration valid. Defender for Endpoint is the alarm system inside the car. Conditional Access is the barrier that only lifts for cars with a valid sticker.

### Risks it mitigates

- **Ransomware** - blocked by Defender for Endpoint, attack surface reduction rules and tamper protection.
- **Info-stealer malware** - detected and isolated before stolen sessions are used.
- **Unpatched software** - Windows Autopatch and Defender vulnerability management close known holes.
- **Lost or stolen laptops** - BitLocker encryption plus remote wipe.
- **Company data on personal phones** - app protection policies keep work data inside managed apps.

### Rollout with two admins

1. **Enroll company Windows devices automatically.** Use Entra join with automatic Intune enrollment. New laptops use Windows Autopilot, so they arrive configured.
2. **Connect Intune to Defender for Endpoint.** Onboarding then happens automatically through Intune - no agent to install by hand.
3. **Apply Microsoft's security baselines** for Windows, Edge and Defender, instead of writing settings from scratch.
4. **Hand patching to Windows Autopatch.** It manages update rings and rollbacks for Windows and Microsoft 365 Apps, which removes a big weekly task.
5. **Run attack surface reduction rules in audit mode for 3-4 weeks.** Review what would have been blocked, add exceptions for real business tools, then switch to block.
6. **Create a compliance policy** and give users a grace period to fix issues.
7. **Protect personal phones without enrolling them.** App protection policies for Outlook, Teams and OneDrive: PIN required, no copy-paste to personal apps, wipe work data on leave.
8. **Enforce in Conditional Access last.** CA08 requires a compliant device for desktop apps. CA09 requires approved apps with app protection on mobile.

### Key configuration

- **Compliance policy (Windows):** BitLocker on; Secure Boot on; Defender antivirus on and current; firewall on; minimum supported OS build; Defender for Endpoint machine risk score at or below *Medium*.
- **Defender for Endpoint:** tamper protection on; EDR in block mode; automated investigation and remediation set to *Full - remediate threats automatically*; network protection on.

- **Attack surface reduction rules (block after audit):** block Office apps from creating child processes; block credential stealing from LSASS; block executable content from email and webmail; block untrusted USB processes; use advanced ransomware protection.
- **Local admin rights:** removed from users; Windows LAPS manages a unique local admin password per device.
- **App protection (iOS/Android):** require PIN or biometrics; block save-as to personal storage; block copy-paste to unmanaged apps; selective wipe after 90 days offline.
- **Conditional Access:** CA08 (compliant device for Windows/macOS desktop access), CA09 (app protection for mobile), CA10 (browser-only, no downloads, for unmanaged devices).

### Tradeoffs and drawbacks

- **The heaviest lift of the five.** Every device must be touched or re-enrolled, and old hardware without TPM 2.0 may fail compliance.
- **False positives.** Attack surface reduction rules can block old macros or line-of-business tools. Audit mode first reduces this, but never to zero.
- **BYOD pushback.** Staff may refuse to enroll personal laptops. Browser-only access (CA10) is the compromise.
- **Mixed estates cost more effort.** Macs need their own profiles and onboarding.
- **Removing local admin rights** creates software-install requests the admins must handle.

## Control 4 · Inbox Shield

*Bad email is caught at the gate, not in the user's head.*

> ***Built with:*** *Defender for Office 365 P2 (preset security policies, Safe Links, Safe Attachments, impersonation protection, attack simulation training), SPF, DKIM, DMARC ·* ***Effort:*** *Low ·* ***Owner:*** *Admin A*

### Why it matters

Email is still the main way attacks get in. It carries the fake login page that steals a password, the attachment that drops malware, and the "urgent invoice" from a fake supplier. For a small business, one paid fake invoice can cost more than a year of IT budget.

Think of it like a mailroom with a scanner. Every letter is X-rayed (Safe Attachments), every address checked (Safe Links), and any letter claiming to be from the CEO is compared against the real CEO's handwriting (impersonation protection).

**Why it ranks fourth, not first:** E7 already turns on basic Safe Links and Safe Attachments by default, and Control 1 removes most of the value of a stolen password. This control closes the remaining gaps - especially payment fraud, which no sign-in control can stop.

### Risks it mitigates

- **Credential phishing** - links are checked again at the moment of click, not just at delivery.
- **Malware attachments** - opened in a sandbox before reaching the user.
- **Business email compromise** - fake CEO, fake supplier and changed-bank-details emails.

- **Domain spoofing** - others sending email that looks like it came from your domain.
- **Data theft through mail forwarding** - hidden rules that copy mail to an outside address.

### Rollout with two admins

1. **Apply the preset security policies.** *Standard* for all users, *Strict* for executives, finance and admins. Microsoft updates these settings over time, so there is nothing to tune by hand.
2. **Add impersonation protection** for the CEO, CFO and finance team, and for the domains of your top suppliers and banks.
3. **Extend protection to Teams, SharePoint and OneDrive.** Safe Attachments for files, Safe Links inside Teams and Office apps.
4. **Fix email authentication in stages.** SPF and DKIM first. Then DMARC at *p=none* to see who sends as you. After 4-6 weeks, move to *quarantine*, then *reject*.
5. **Block automatic external forwarding** in the outbound spam policy.
6. **Turn on the built-in Report button** in Outlook, with automated investigation on user-reported emails.
7. **Run a phishing simulation every quarter** with short training assigned automatically to anyone who clicks.

### Key configuration

- **Preset policies:** Standard → all users; Strict → a priority group (executives, finance, admins). Priority account protection on for the same group.
- **Impersonation:** protected users (CEO, CFO, finance leads), protected domains (top suppliers, banks), mailbox intelligence on.
- **Safe Attachments:** on for SharePoint, OneDrive and Teams; Safe Documents on.
- **Safe Links:** URL rewriting on; check at click time; wait for scan before delivery; no click-through.
- **Email authentication:** SPF hard fail; DKIM signing on for every custom domain; DMARC *p=none* → *quarantine* → *reject* with aggregate reports to a shared mailbox.
- **Outbound:** external auto-forwarding off; SMTP AUTH off tenant-wide (exceptions only for named service accounts).
- **Quarantine:** users can request release; admins approve high-confidence phishing releases only.

### Tradeoffs and drawbacks

- **Some good mail gets quarantined.** Strict policies catch more false positives. Someone must review quarantine requests a few times a week.
- **DMARC can break legitimate senders.** Invoicing tools, CRMs and marketing platforms that send as your domain must be listed in SPF/DKIM first, or their mail will bounce.
- **Link rewriting looks odd** to some users and can confuse partners who receive forwarded mail.
- **Simulations can feel like a trap.** Keep them educational, never punitive, or staff stop reporting real phishing.

## Control 5 · Data and AI Guardrails

*Sensitive data stays inside - whoever, or whatever, is asking for it.*

> ***Built with:*** *Microsoft Purview (sensitivity labels, DLP, Data Security Posture Management for AI), SharePoint Advanced Management, Agent 365, Defender for Cloud Apps* · ***Effort:*** *High* · ***Owner:*** *Admin A and B, with business data owners*

### Why it matters

E7 gives every user Microsoft 365 Copilot. Copilot can only see what the user can already see - but it finds it in seconds. A salary sheet shared with "Everyone" five years ago was hidden by obscurity. With Copilot, anyone can ask "show me salaries" and get an answer.

Think of Copilot as a very fast librarian. It never breaks into locked rooms, but it will happily fetch anything left on an open shelf. This control locks the right rooms, labels the sensitive books, and stops them leaving the building.

AI agents add a new layer. Staff can build agents in Copilot Studio that read data and take actions. Agent 365 gives the admins one list of every agent, who owns it and what it can touch.

### Risks it mitigates

- **Oversharing** - old SharePoint sites and Teams open to the whole company or to "anyone with the link".
- **Copilot surfacing sensitive content** to people who should never have had access.
- **Accidental leaks** - customer data emailed outside, copied to USB, or uploaded to personal cloud storage.
- **Shadow AI** - staff pasting company data into public AI tools.
- **Agent sprawl** - unowned agents with broad access and no review.
- **Compliance exposure** under data protection laws for personal and financial data.

### Rollout with two admins

1. **Find the overshared data first.** Run the SharePoint data access governance and oversharing reports, and the Data Security Posture Management for AI assessment. Fix the top sites before Copilot goes to all users.
2. **Change default sharing.** Default link type *Specific people*; *Anyone* links off or limited to 30-day expiry; external sharing only for named sites.
3. **Hide sensitive sites from Copilot while they are cleaned.** Use Restricted Content Discovery on HR, finance and legal sites.
4. **Publish a small label set.** Four labels are enough: *Public, General, Confidential, Highly Confidential*. Default label *General* for new documents and email.
5. **Auto-label the obvious.** Service-side auto-labeling for payment card numbers, national ID numbers and bank details.
6. **Turn on DLP in simulation mode.** Use Microsoft's templates for financial and personal data. Review matches for 2-3 weeks, add policy tips, then block.
7. **Govern AI use.** DLP for the Copilot location so *Highly Confidential* files are not processed by Copilot. Block unsanctioned AI sites through Defender for Cloud Apps. Register and review agents in Agent 365.
8. **Train the data owners.** One 30-minute session per department on what each label means. The admins should not be the ones labelling.

### Key configuration

- **Labels:** Confidential and Highly Confidential apply encryption; Highly Confidential blocks forwarding and external sharing; label inheritance on for Copilot-created content.
- **DLP - Exchange, SharePoint, OneDrive, Teams:** block external sharing of content with 10 or more personal or card records; policy tip with override and business reason for smaller matches.
- **DLP - endpoints:** devices from Control 3 are onboarded automatically; block copy to USB and personal cloud for labelled content; audit uploads to AI websites.
- **DLP - Microsoft 365 Copilot location:** exclude *Highly Confidential* content from Copilot responses.
- **SharePoint:** default link *Specific people*; site access reviews for owners of overshared sites; inactive site policy on.
- **Agents:** only a named maker group can publish agents org-wide; every agent has an owner; quarterly review in Agent 365.
- **Audit:** Purview Audit (Premium) on, so Copilot and agent activity is logged and searchable.

### Tradeoffs and drawbacks

- **Most change management of the five.** Labels only work when people understand them. Expect questions and some wrong labels at first.
- **DLP can block real work.** Too strict and staff look for workarounds. Simulation mode and override-with-reason keep this in check.
- **Clean-up needs business time.** Site owners, not admins, must decide who should have access. This is the slowest step.
- **Copilot gives less value while data is locked down.** Restricted discovery reduces what Copilot can answer until sites are fixed.
- **Never "done".** New sites, new agents and new data types need ongoing tuning.

## Beyond the top five

These controls are worth adding once the top five are live. Most are also included in E7. They come later because they either depend on the five being in place, or they reduce a smaller slice of risk for the effort involved.

### Next wave (months 4-6)

- **Joiner-mover-leaver automation** (Entra ID Governance lifecycle workflows). Accounts are created, changed and disabled automatically from HR events. Stops former staff keeping access - a common gap in small firms.
- **Guest and external access reviews.** Quarterly reviews remove old partners and contractors from Teams and SharePoint. Teams external chat limited to allowed domains.
- **SaaS and OAuth app governance** (Defender for Cloud Apps). Finds unsanctioned cloud apps in use and flags OAuth apps with risky permissions to mail and files.
- **Insider Risk Management** (Purview). Starts with the *data theft by departing users* template, the most relevant one for a business this size.

- **Microsoft 365 data recovery plan.** Retention policies, recycle-bin and versioning settings, and a tested restore process. Microsoft 365 is not a backup on its own; a backup service (Microsoft 365 Backup or a third-party tool) is a separate purchase worth pricing.

### Later wave (months 6-12)

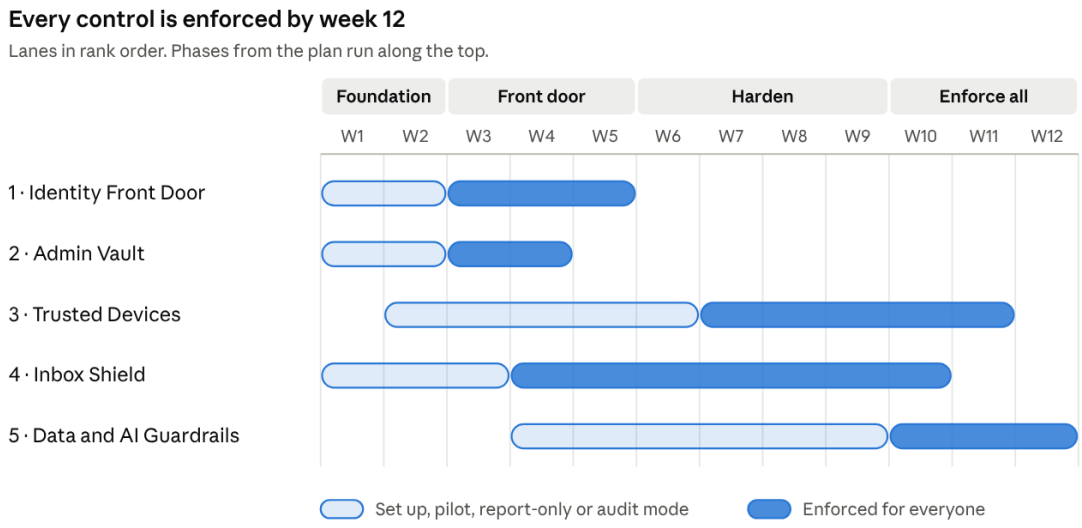
- **Replace the VPN with Entra Private Access.** Access to internal apps per user and per app, checked by Conditional Access, instead of a full network tunnel.
- **Web filtering with Entra Internet Access.** Blocks risky site categories and adds the same identity checks to internet traffic.
- **Defender for Identity** if any on-premises Active Directory remains. Detects attacks on domain controllers that cloud tools cannot see.
- **Exposure management and Secure Score reviews.** A monthly look at the top recommended actions, tracked as a short backlog.
- **Out-of-hours coverage.** Two admins cannot watch alerts at night or over weekends. A managed detection and response service (for example Microsoft Defender Experts, a paid add-on, or a partner MDR) covers this gap.

### Ongoing hygiene (always on)

- Monthly review of Conditional Access changes and sign-in failures.
- Quarterly security awareness session alongside the phishing simulations.
- Annual tabletop exercise: walk through a ransomware or fake-invoice incident with management.

## 12-week rollout roadmap

All five controls are enforced by the end of week 12. Rank decides importance; effort decides order. That is why the Inbox Shield starts in week 1 even though it ranks fourth - its presets take an afternoon.




12-week rollout · 5 controls, 4 phases

Every control is tested quietly before it is enforced. The two heavy controls - Trusted Devices and Data and AI Guardrails - get the longest set-up time.

## Phase by phase

1. **Weeks 1-2 · Lay the foundation**
    - Create break-glass accounts and separate admin accounts
    - Build Conditional Access policies CA01-CA07 in report-only
    - Apply Standard and Strict email presets; set up SPF, DKIM and DMARC *p=none*
    - Configure automatic Intune enrollment and the Defender for Endpoint connector
2. **Weeks 3-5 · Lock the front door**
    - Passkey registration campaign, then enforce CA01-CA07 in waves
    - Turn on PIM for every admin role
    - Add impersonation protection; start Windows Autopatch; attack surface reduction rules in audit
    - Run the SharePoint oversharing and AI data risk reports
3. **Weeks 6-9 · Harden devices and email**
    - Compliance policies live with a grace period; attack surface reduction rules to block
    - App protection on mobile; DMARC to *quarantine*
    - New sharing defaults; publish sensitivity labels; DLP in simulation
4. **Weeks 10-12 · Enforce everywhere**
    - CA08-CA10 require compliant devices and app protection
    - DMARC to *reject*; DLP switched to block
    - Copilot opened to all users; agents registered and reviewed in Agent 365
    - First quarterly access review and break-glass test

### Go / no-go checks before each enforcement step

- **Before enforcing sign-in policies:** report-only shows no unexpected blocks; 95% of users have registered a strong method; break-glass sign-in tested.
- **Before requiring compliant devices:** 95% of company devices compliant for a full week; exceptions documented.
- **Before DMARC reject:** every known sending service passes SPF or DKIM for two weeks.
- **Before Copilot for everyone:** top overshared sites fixed or hidden; *Highly Confidential* content excluded from Copilot.

## Running it with two admins

Two admins can run this estate in about 30 minutes a day, if Microsoft's automation does the first pass and each admin owns clear areas.

### Who owns what

- **Admin A - identity and communication:** Identity Front Door, Inbox Shield, Data and AI Guardrails (policy side).
- **Admin B - privilege and devices:** Admin Vault, Trusted Devices, Data and AI Guardrails (endpoint and agent side).

- **Each admin is the other's backup.** Both can do every task; ownership only decides who looks first. A one-page runbook per control makes the handover easy during leave.

### Let automation do the first pass

- **Automated investigation and response** in Defender XDR closes most routine alerts (a malicious email removed from all inboxes, a suspicious file quarantined) without a person.
- **Preset email policies and Microsoft-managed Conditional Access policies** update themselves as Microsoft learns of new attacks.
- **Windows Autopatch** handles patch rings and rollbacks.
- **Security Copilot** (where included in the tenant) summarises incidents and explains scripts, so a generalist admin can triage faster.
- **One incident queue.** Defender XDR joins email, device, identity and app alerts into single incidents, so nothing is checked in five portals.

### The routine

- **Daily (15-30 min):** open the Defender XDR incident queue; handle high-severity incidents; check risky users in Identity Protection.
- **Weekly (1 hour):** quarantine release requests; device compliance failures; PIM activations and new role assignments; DMARC reports during rollout.
- **Monthly (half a day):** Secure Score review and top three actions; Conditional Access change log; DLP false-positive tuning; phishing simulation results.
- **Quarterly:** access reviews for admins and guests; break-glass sign-in test; agent review in Agent 365; restore test for a sample of files.

## What two admins cannot do

They cannot watch alerts at 2 a.m. on a Sunday. Automation contains most threats, but a human decision may wait until morning. If the business cannot accept that, budget for a managed detection and response service (see *Beyond the top five*).

## Measuring success

At week 12, the plan is working if these numbers hold. Track them monthly in one short report to management.

- **Identity Front Door:** 95%+ of users sign in with passkeys or Windows Hello; zero legacy-authentication sign-ins.
- **Admin Vault:** zero permanent admin roles except the two break-glass accounts; every activation logged with a reason.
- **Trusted Devices:** 95%+ of company devices compliant; critical patches applied within 14 days.
- **Inbox Shield:** DMARC at *reject*; phishing simulation click rate falling quarter on quarter; report rate rising.
- **Data and AI Guardrails:** top overshared sites fixed; sensitive content labelled; every AI agent has a named owner.

- **Overall:** Microsoft Secure Score trending up month on month, with the top recommendations either done or consciously accepted.